
IFESEC

Ijezie Risk Advisory

AtlasPay

SOC 2 Type 1 Readiness Assessment

Executive Briefing

Prepared for: AtlasPay, Inc. Executive Leadership

Engagement: FinTech Payment Processor — SOC 2 Type 1 Readiness

Framework: AICPA SOC 2 Trust Services Criteria, Revision 2022

Scope: Common Criteria (CC) + Availability (A) + Confidentiality (C). Processing Integrity (PI) and Privacy (P) excluded from this engagement.

Audit window target: Q4 2026 (October-December)

Report date: 2026-06-25

Engagement period: FY 2026 Q2-Q3

Prepared by: IfeSec | Ijezie Risk Advisory

Classification: INTERNAL // EXECUTIVE READY

Executive Summary

AtlasPay has retained IfeSec to conduct a pre-audit SOC 2 Type 1 readiness assessment covering Common Criteria (CC), Availability (A), and Confidentiality (C). This briefing summarizes the engagement's findings for the executive leadership team.

AtlasPay has a functioning control environment. The engagement validated six risk scenarios, mapped them against the SOC 2 Trust Services Criteria, and identified 14 audit walkthrough findings — zero Critical, four High, seven Medium, three Low.

The most material finding is R-04 (Third-Party SaaS Breach), which we recommend be formally accepted at residual High by the Risk Committee. Supply-chain compromise is endemic in FinTech, and AtlasPay's TPRM program and contractual protections reduce blast radius but cannot eliminate occurrence probability. Honest residual scoring here is more defensible than claiming reduction that an auditor would challenge.

With completion of the four High-severity remediation items by 2026-09-30, AtlasPay is positioned for an unqualified SOC 2 Type 1 opinion in the Q4 2026 audit window.

Inherent Risk Profile (6 Risk Scenarios)

Critical	Very High	High	Medium	Low	Very Low
0	0	1	3	2	0

Residual Risk Distribution After Mitigation

Level	Count	Risks
High	1	R-04 (Vendor Breach) — formally accepted
Medium	4	R-01, R-02, R-03, R-05
Low	1	R-06 (Audit Logging)

Methodology

The engagement followed the standard vCISO pre-audit methodology for SOC 2 Type 1 readiness:

- 1** **Scope & Stakeholder Alignment**
Define audit scope (CC + A + C), identify stakeholders, confirm audit window target.
- 2** **Framework Loading**
Load SOC 2 TSC 2022 and supporting mappings (NIST CSF, ISO 27001) into CISO Assistant.
- 3** **Risk Register Build**
Identify 6 risk scenarios, score on 5x5 ISO-27005 matrix, develop treatment plans.
- 4** **Control Mapping**
Map 4 policies + 7 vendors + 6 risks against 38 SOC 2 TSC criteria in scope.
- 5** **Gap Assessment**
Classify each criterion as Covered / Partial / Missing. Document remediation roadmap.
- 6** **Audit Walkthrough Simulation**
vCISO acts as SOC 2 auditor, walks the platform, surfaces findings, develops management response.

Risk Scoring Reference

All risk scoring uses the 5x5 ISO-27005 matrix (AtlasPay 5x5, URN: urn:atlaspay-5x5, deployed in CISO Assistant v3.18.3). Probability and impact are scored 1-5; the matrix lookup produces the composite level (Very Low, Low, Medium, High, Very High).

Audit Walkthrough Findings

The audit walkthrough surfaced 14 findings across the SOC 2 Trust Services Criteria. Severity ratings reflect the auditor's anticipated response during a Type 1 audit. Management responses and remediation timelines are documented for each.

Severity	Count	Findings
High (4)	Material gap requiring remediation before audit window	AW-02, AW-03, AW-04, AW-06
Medium (7)	Design exists, evidence incomplete or remediation in progress	AW-05, AW-07, AW-08, AW-10, AW-12, AW-13
Low (3)	Minor documentation gap; auditor likely accepts vendor explanation	AW-01, AW-09, AW-14

High-Severity Findings (Material)

but not operational. No vendor selected, no HRIS integration.

HRIS integration by Q4 2026.

Target: 2026-08-15

retained scan reports.

n for Q3 2026. Initial report by 2026-09-01.

Target: 2026-09-01

documented as formal control. No CAB minutes.

ge Management Policy within 2 weeks. Establish CAB weekly cadence.

Target: 2026-07-15

o formal cadence, no retention, no SLA.

ted scans within 1 week. Remediation SLA: Critical 7d, High 30d, Medium 90d.

Target: 2026-07-08

Recommendations

The following recommendations are derived from the audit walkthrough findings and the residual risk acceptance narrative. They are sequenced by urgency and dependency.

Engage external pen test firm (AW-03) first as it has the longest lead time. Document Change Management Policy (AW-04) second as it requires CTO sign-off. V-06 in parallel as both require vendor + engineering coordination.

Decision with explicit conditions: quarterly vendor risk review, annual SOC 2 Type 2 review for Tier-1 vendors, contractual sub-processor notification rights to be sustained.

Test scope should cover V-01 (AWS), V-02 (Payment Gateway), V-04 (Application Platform / K8s). Findings remediation tracked through V-05 with Criticality 1.

Control; documentation formalizes it. Establish weekly CAB meeting for production changes. Retain deployment logs for 12 months minimum.

Control; documentation formalizes it. Sign MSA. Integrate with HRIS. Define background check scope: identity, criminal, credit (for finance roles), employment history. Update onboarding process.

Subscribe to CVE feeds for V-01, V-02, V-04 dependencies. Weekly vulnerability review meeting with CISO + Engineering Lead.

3, AW-10, AW-12, AW-13

Readiness: AW-08 (board reporting) and AW-13 (risk acceptance documentation) are quick wins. AW-10 (tabletop) and AW-12 (DR plan) require more investment.

Appendix: Risk Register

The full risk register is documented in the CISO Assistant platform (folder AtlasPay, risk assessment RA-ATLASPAY-SOC2). The table below shows the engagement-finalized residual scoring.

ID	Risk	Inherent	Current	Residual	Treatment	Owner
R-01	Privileged Account Compromise	Very High	Medium	Medium	Mitigate	CISO
R-02	Payment Data Exfiltration via API	Very High	Medium	Medium	Mitigate	CISO + CTO
R-03	Ransomware on Production Database Host	High	Medium	Medium	Mitigate	CTO + CISO
R-04	Third-Party SaaS Breach (Vendor Compromise)	High	High	High	Accept (with mitigation)	CISO + Vendor Management
R-05	Insider Threat (Malicious Employee)	High	High	Medium	Mitigate	Head of People + CISO
R-06	Insufficient Audit Logging	High	Low	Low	Mitigate	CISO + Engineering

Risk Acceptance Statement — R-04

The Risk Committee has formally accepted residual High for R-04 (Third-Party SaaS Breach) with the following conditions: (1) quarterly vendor risk review with documented minutes; (2) annual SOC 2 Type 2 review for all Tier-1 vendors; (3) contractual sub-processor notification rights enforced; (4) annual tabletop exercise simulating vendor breach; (5) cyber insurance policy maintained with vendor breach coverage.

If any of these conditions cannot be maintained, R-04 should be re-evaluated for treatment change (likely transfer via cyber insurance or escalate to board for risk avoidance discussion).

Appendix: Engagement Artifacts

The following artifacts are produced by this engagement and stored in the AtlasPay sandbox repository for ongoing reference.

Artifact	Location	Description
Risk Register (full)	lab/docs/soc2-risk-register.md	6 risk scenarios with inherent/current/residual scoring and treatment plans
SOC 2 Control Mapping	lab/docs/soc2-control-mapping.md	38 SOC 2 TSC criteria mapped to policies, risks, and vendors
Gap Assessment	lab/docs/soc2-gap-assessment.md	13 remediation items with severity, owner, target date
Audit Walkthrough	lab/docs/soc2-audit-walkthrough.md	10 walkthrough questions + 14 findings + management response
CISO Assistant Folder	live state, AtlasPay folder	Risk scenarios, policies, vendors, risk assessment
Risk Assessment Container	RA-ATLASPAY-SOC2	Risk Assessment in CISO Assistant holding the 6 risk scenarios

Closing Notes

This briefing is produced as part of an lfeSec SOC 2 Type 1 readiness engagement. The findings, recommendations, and remediation roadmap reflect consultant judgment based on artifacts in the AtlasPay sandbox and the engagement's risk register finalization.

Lab-synthetic disclaimer: The risk register values, control mapping status, and audit walkthrough findings reflect a portfolio demonstration engagement. In a real SOC 2 Type 1 readiness engagement, these would be derived from AtlasPay's actual operational state, validated through interviews, observation, and inspection.

lfeSec | ljezie Risk Advisory

Independent vCISO and Risk Advisory practice. SOC 2 readiness, ISO 27001, HIPAA, FFIEC.
